The compliance-policy Q&A copilot

Foundations of Agentic Logic · fictional composite, not based on any named institution

The scenario

A bank's compliance team builds an internal chatbot so staff can ask questions about internal policy (“can we offer this product to a customer in this situation?”) instead of searching a policy portal manually. It's built on retrieval over the compliance document repository, refreshed nightly.

Uptake is high. Two issues surface in a routine review:

- The retrieval index was built by a service account with read access to the entire document repository, including draft policies not yet approved and HR policy documents unrelated to customer-facing compliance.
- A support engineer notes that the semantic cache is returning answers based on similar-sounding questions from weeks earlier, including at least one case where the underlying policy had since been updated.

Discussion questions

1. **Is this system correctly described as “retrieval,” or has it become agentic in the sense used this morning? What would need to be true for it to count as agentic RAG?**

2. **Walk through the security-trimming failure here in the terms used in this morning's session: what's the mismatch, and who could see what they shouldn't?**

3. **The stale-cache issue is a different failure from the access-control issue. What control addresses each one, and is it the same control?**

4. **This system's failure mode is “confidently wrong policy advice,” not “system unavailable.” Why does that distinction matter for how you'd prioritise fixing it?**